Tema: Seguridad y Auditoria de Bases de Datos
Controles ISO 27001:2022 para la
Confidencialidad en Administración de Bases de Datos

Curso: Administración de Bases de Datos
Escuela de Informática - Universidad Nacional
Prof. Johnny Villalobos Murillo | II Ciclo 2026

1. Presentación y Justificación

En el contexto actual, la confidencialidad de la información es uno de los pilares de la seguridad. El Administrador de Bases de Datos (DBA) es el custodio técnico de los activos de información más críticos. Esta asignación busca que el estudiante comprenda, diseñe e implemente controles basados en ISO/IEC 27001:2022 e ISO/IEC 27002:2022 para mitigar riesgos de confidencialidad, aplicando el ciclo PHVA y el principio de mínimo privilegio.

2. Objetivo General

Diseñar e implementar un marco de controles basado en ISO/IEC 27001:2022 (Anexo A) e ISO/IEC 27002:2022 para mitigar riesgos de confidencialidad en las tareas del Administrador de Bases de Datos, incluyendo matriz de evaluación y pruebas observables auditables.

3. Objetivos Específicos

- Identificar y clasificar al menos 5 riesgos de confidencialidad (R-CONF) asociados a motores de BD (Oracle).
- Mapear al menos 12 tareas críticas del DBA (gestión de usuarios, privilegios, autenticación, cifrado TDE, masking, backup, auditoría, parcheo, listener, eliminación segura, logs, clones DEV/TEST).
- Seleccionar y justificar controles del Anexo A 2022 pertinentes (A5.12, A5.15, A5.16, A5.17, A5.18, A5.33, A8.2, A8.3, A8.5, A8.10, A8.11, A8.12, A8.13, A8.15, A8.20).
- Diseñar una Matriz de Evaluación con criterios de madurez 0-4, evidencia y estado (Cumple/No cumple/Parcial).
- Proponer y ejecutar pruebas técnicas (consultas SQL, revisión de configuraciones, auditorías) que demuestren la efectividad de los controles.

4. Competencias a Desarrollar

- Genéricas: Pensamiento crítico, trabajo autónomo, comunicación técnica, ética profesional, aprendizaje continuo.
- Específicas: Administración segura de BD, implementación de controles ISO 27001, auditoría de privilegios, gestión de identidades y accesos (IAM/PAM), cifrado y enmascaramiento de datos, cumplimiento Ley de Protección de Datos 8968 Costa Rica.

5. Análisis de Temas Relacionados (Marco Teórico)

El estudiante debe investigar y sintetizar brevemente (2-3 páginas):
- Cambios ISO 27001:2022 respecto a 2013: nuevo Anexo A con 93 controles en 4 temas.
- Principio de mínimo privilegio y separación de funciones en el rol DBA.
- Defensa en profundidad y Zero Trust aplicado a bases de datos.
- Controles técnicos: Transparent Data Encryption (TDE), Dynamic Data Masking, Data Redaction, Row Level Security / VPD, TLS para conexiones.
- Data Leakage Prevention (DLP) y gestión de backups cifrados.
- Logging, monitoreo y correlación (SIEM).
- Normativa costarricense: Ley 8968 Protección de la persona frente al tratamiento de sus datos personales y su reglamento.

6. Producto Esperado - El Artefacto

Cada estudiante/grupo debe entregar un artefacto (interactivo HTML, PDF o sitio) que contenga:
1) Tabla de riesgos R-CONF-01 a R-CONF-05 con impacto y probabilidad.
2) Tabla de tareas del DBA.
3) Mapeo de controles ISO con implementación sugerida y evidencia observable (ej: SELECT * FROM DBA_SYS_PRIVS, pg_hba.conf, SELECT * FROM v$encryption_wallet).
4) Lista de 15 controles observables por auditor externo.
5) Matriz de evaluación (Tarea | Riesgo | Control | Criterio 0-4 | Evidencia | Estado).
6) Batería de pruebas (ID, Tipo, Procedimiento, Resultado esperado, Herramienta).
Obligatorio incluir scripts de verificación.

7. Propuesta de Herramienta y Metodología

Motor: Oracle 19c/21c XE
Metodología: PHVA (Planificar-Hacer-Verificar-Actuar).
Herramientas: SQL Developer
Documentación: APA 7, repositorio Git institucional, video explicativo 5 minutos.

8. Uso Ético y Documentado de Inteligencia Artificial - SECCIÓN OBLIGATORIA

El uso de IA generativa (Meta AI, ChatGPT, Claude, Gemini) está PERMITIDO y FOMENTADO, siempre que se documente correctamente. El uso sin documentar se considera plagio según el Reglamento de Faltas Estudiantiles UNA.

Debe incluir en el informe una sección con la siguiente tabla:

Herramienta IA	Prompt Exacto Utilizado	Aporte de la IA	Validación / Corrección del Estudiante	Fuente Verificada
Ej: Meta AI	Ej: Dame controles ISO 27001 para riesgo confidencialidad DBA	Lista inicial de controles	Verifiqué en ISO 27002:2022 y descarté A8.4, agregué A8.11	ISO/IEC 27002:2022 - Cap 8.11

- Declaración Jurada:
- Yo, [Nombre del estudiante], declaro que todo contenido generado con IA ha sido declarado en la tabla anterior, validado contra fuentes oficiales (ISO, documentación del motor de BD) y que asumo responsabilidad por su veracidad. Entiendo que omitir esta declaración constituye falta grave.

9. Rúbrica de Evaluación (100 pts)

Criterio	Peso	Descripción
Identificación de Riesgos y Tareas DBA	20%	Claridad, completitud, pertinencia técnica
Mapeo y Justificación de Controles ISO	20%	Selección correcta A5/A8, justificación y evidencia
Matriz de Evaluación y Controles Observables	20%	Criterios 0-4 bien aplicados, evidencias auditables
Pruebas Técnicas y Scripts	15%	Scripts funcionales, resultados esperados realistas
Documentación de Uso de IA y Referencias APA 7	15%	Tabla completa, honestidad, validación
Presentación, Video y Repositorio	10%	Claridad, formato, entrega a tiempo

10. Entregables

- 1. Informe PDF con artefacto (o link a artefacto interactivo)
  2. Scripts .sql de verificación
  3. Repositorio Git
  4. Video 5 minutos
  5. Tabla de uso de IA firmada